

SOC - Déploiement de Sysmon et Collecte Hybride

L'observateur d'événements Windows est insuffisant pour traquer les hackers avancés. Nous allons déployer Sysmon sur le Contrôleur de Domaine, et envoyer les alertes en temps réel vers notre machine Linux pour les sanctuariser.

Préparation du Collecteur SIEM

Nous allons transformer notre Linux en serveur de réception de logs (Syslog) pour écouter ce que le serveur Windows va lui envoyer.

Connectez-vous sur votre machine **Linux**.

Éditez le fichier de configuration de Rsyslog :

```
sudo nano /etc/rsyslog.conf
```

Décommentez (retirez le #) ces deux lignes pour activer la réception sur le port TCP 514 :

```
module(load="imtcp")  
  
input(type="imtcp" port="514")
```

Sauvegardez et quittez (**CTRL+O**, **Entrée**, **CTRL+X**).

Redémarrez le service pour appliquer l'écoute :

```
sudo systemctl restart rsyslog
```

Ouvrez le pare-feu local (UFW) pour autoriser le port 514 en provenance de votre serveur Windows (Remplacez **<IP_WINDOWS>** par la vraie IP) :

```
sudo ufw allow from <IP_WINDOWS> to any port 514 proto tcp
```

Déploiement de l'Agent Sysmon (Sur le Windows Server)

L'installation de Sysmon nécessite le programme et un fichier de configuration XML (le filtre).

Sur le serveur **Windows**, ouvrez un navigateur et téléchargez Sysmon depuis le site de Microsoft : 🖱️ <https://download.sysinternals.com/files/Sysmon.zip>

Téléchargez le profil de sécurité standard de l'industrie (SwiftOnSecurity) : 🖱️ Allez sur <https://github.com/SwiftOnSecurity/sysmon-config> et téléchargez le fichier

`sysmonconfig-export.xml`.

Extrayez Sysmon dans un dossier (ex: `C:\Outils\`). Placez le fichier `sysmonconfig-export.xml` dans le même dossier.

Ouvrez **PowerShell en tant qu'Administrateur**, placez-vous dans le dossier, et installez Sysmon avec cette commande :

```
cd C:\Outils\
```

```
.\Sysmon64.exe -accepteula -i sysmonconfig-export.xml
```

(Le système doit vous confirmer que le service Sysmon est installé et démarré).

La Collecte Croisée (NXLog vers Linux)

Windows ne sait pas envoyer de Syslog nativement. Nous utilisons **NXLog** (l'agent gratuit le plus utilisé en entreprise) pour faire la traduction.

1. Téléchargez et installez **NXLog Community Edition** (format `.msi`) depuis leur site officiel. L'installation par défaut suffit.
2. Ouvrez le bloc-notes (**Notepad**) en tant qu'**Administrateur**.
3. Ouvrez le fichier de configuration : `C:\Program Files\nxlog\conf\nxlog.conf`.

Effacez tout le contenu et remplacez-le par cette configuration (N'oubliez pas de **remplacer l'IP** par celle de votre Linux) :

Panic Soft

```
#NoFreeOnExit TRUE
```

```
define ROOT    C:\Program Files\nxlog
```

```
define CERTDIR %ROOT%\cert
```

```
define CONFDIR %ROOT%\conf
```

```
define LOGDIR  %ROOT%\data
```

```
define LOGFILE %LOGDIR%\nxlog.log
```

```
LogFile %LOGFILE%
```

```
Moduledir %ROOT%\modules
```

CacheDir %ROOT%\data

Pidfile %ROOT%\data\nxlog.pid

SpoolDir %ROOT%\data

<Extension syslog>

Module xm_syslog

</Extension>

<Input in_sysmon>

Module im_msvistalog

On ne capture QUE le journal Sysmon

<QueryXML>

<QueryList>

<Query Id="0">

<Select Path="Microsoft-Windows-Sysmon/Operational">*</Select>

</Query>

</QueryList>

</QueryXML>

</Input>

<Output out_ubuntu>

Module om_tcp

Host 10.100.55.102 # <--- REMPLACEZ PAR L'IP DE VOTRE LINUX

Port 514

Exec to_syslog_snare();

</Output>

```
<Route sysmon_to_ubuntu>
```

```
Path    in_sysmon => out_ubuntu
```

```
</Route>
```

Sauvegardez le fichier.

Dans PowerShell (Admin), démarrez l'agent NXLog :

```
Start-Service nxlog
```

PARTIE 4 : Le Crash-Test (Simulation d'une attaque Ransomware)

Votre système de surveillance est en place. Nous allons simuler une technique de pirate très classique ("Living off the Land") : la suppression des clichés instantanés pour empêcher la restauration avant de lancer un ransomware.

1. Restez sur le serveur **Windows**.
2. Ouvrez une invite de commande `cmd.exe`.

Tapez la commande suivante (elle va simuler l'attaque, bien qu'elle génère une erreur inoffensive dans ce lab) :

```
vssadmin delete shadows /all /quiet
```

Exécutez une autre commande suspecte (téléchargement masqué via un outil légitime) :
`certutil.exe -urlcache -split -f http://www.google.fr test.txt`

L'Investigation du SOC

C'est ici que l'architecte gagne son salaire. Le pirate pense avoir effacé ses traces sur Windows, mais la preuve est déjà sur la machine Linux.

1. Basculez sur votre machine **Linux**.

Ouvrez un terminal et inspectez le fichier journal général qui a réceptionné l'alerte Windows :
`sudo tail -n 50 /var/log/syslog | grep -i sysmon`

2. (Vous pouvez aussi utiliser `less /var/log/syslog` et chercher `vssadmin`).

Vous allez voir apparaître des lignes de log contenant l'**Event ID 1** (Process Creation) provenant de Sysmon. À l'intérieur de ces lignes, vous trouverez :

- La commande exacte tapée par le pirate (`vssadmin delete shadows...` et `certutil...`).
- Le chemin exact de l'exécutable.
- Le hachage cryptographique du processus (SHA256).
- Le processus parent qui a lancé l'attaque.

Mission accomplie : Vous avez créé une boucle de sécurité asymétrique. Même si le Windows est détruit, l'analyse Forensic reste possible depuis le Bastion Linux !